

Stream A — Production Readiness

13.09.2026 · Alltagsengel UG · interner Bericht

Jede Aussage trägt ihre Herkunft: **VERIFIED_LIVE** (gegen das laufende System gemessen), **VERIFIED_LOCAL** (Test/Typecheck im Repo), **READY_TO_APPLY** (geschrieben, nicht eingespielt), **UNKNOWN** (nicht feststellbar — und zwar ausdrücklich, nicht stillschweigend).

Commits dieses Laufs: 5c0e92ad, 45b134ce.

0. Was sofort auf den Tisch gehört

Befund	Status	Wer muss handeln
Repo ist public — und die 12 entfernten PII-PDFs sind über alte Commit-SHAs weiter anonym abrufbar	VERIFIED_LIVE	USER_ACTION_REQUIRED
GitHub-OAuth-Token im Klartext in .git/config	VERIFIED_LIVE	ROTATION_REQUIRED
www.alltagsengel.org liefert eine fremde Altseite („AlltagsEngel e.V.“, GitHub Pages)	VERIFIED_LIVE	Klärung
50 Leads in der DB, keiner je bearbeitet: 0 Wiedervorlagen, 0 Verlauf, 0 Audit-Einträge	VERIFIED_LIVE	Betrieb

Priorität 1 — Security

1.1 Sichtbarkeit des Repos — VERIFIED_LIVE

private: False visibility: public forks: 0

Alle vier Repos des Kontos sind public.

Das entwertet Weg A des History-Plans. docs/reports/HISTORY_CLEANUP_PLAN.md

nennt „Repo ist privat“ als empfohlenen Weg — diese Voraussetzung war nie erfüllt. Der Plan ist an dieser Stelle zu korrigieren, nicht zu befolgen.

1.2 PII-Perimeter — VERIFIED_LIVE

Referenz	Ergebnis
main (6 Stichproben, inkl. URL-kodiertes §45a-...)	404 — sauber
e5785561 (Führungszeugnis GF)	200
aac2b162 (Führungszeugnis, IK/Bank)	200
6b6dc335 (Berufsurkunde, Name + Geburtsdatum)	200
5e9886b1 (Haftpflichtpolice)	200

Abgerufen ohne Anmeldung, mit reinem curl. Auf einem öffentlichen Repo lässt sich die Commit-Liste anonym abfragen — „wer die SHA kennt“ heißt praktisch **jeder**.

Nicht getan, weil ausdrücklich gesperrt: History-Rewrite, filter-repo, Force-Push. Die Entscheidung (Repo privat stellen vs. BFG nach Backup) liegt beim Inhaber.

1.3 Secret-Scan — VERIFIED_LIVE

scripts/ci-secret-scan.sh: **clean**. Eigener Breitband-Scan über acht

Muster, Ausgabe bewusst nur Pfad/Typ/Schwere:

Fund	Bewertung
3 Testdateien mit BEGIN ... PRIVATE KEY	Fehlalarm — nur der Marker-String als Fixture (Länge 17-25), kein Schlüsselmateriale
~50 × „Resend-Key“ in graphify-out/	Fehlalarm — reine Kleinbuchstaben ohne Ziffern; echte Keys sind base62. Ordner ist gitignored, ungetrackt, auf GitHub 404
android/app/google-services.json → Google-API-Key	MITTEL, echt . Firebase-Client-Keys sind konstruktionsbedingt öffentlich, gehören aber auf einem public Repo in der GCP-Konsole eingeschränkt (App-Signatur + API-Restriktion)
Remote-URL in .git/config mit gho_...	KRITISCH für die Hygiene . Nicht versioniert, aber Klartext auf der Platte. Credential-Helper wäre der saubere Weg

Keine .env versioniert (nur .env.example). Kein JWT in versionierten Dateien.

1.4 deploy.sh gegen Parallel-Sitzungen — VERIFIED_LOCAL, Commit 5c0e92ad

Ohne DEPLOY_PATHS wird jetzt (a) aufgelistet, was eingesammelt wird, und

(b) abgebrochen, wenn eine Datei **während** des Laufs geschrieben wurde.

Das ist die verlässliche Signatur: eigene Änderungen sind vor dem Aufruf fertig, fremde entstehen weiter.

Eine Karenz von fünf Sekunden fängt den häufigsten Fall ab — Datei schreiben, sofort deployen — weil date +%s nur sekundengenau ist. Ohne sie hätte der Riegel bei fast jedem Lauf falsch ausgelöst; der Fehler tauchte im ersten Testdurchlauf auf.

Vier Fälle geprüft, Logik dafür **aus** deploy.sh **extrahiert**, nicht nachgebaut:

Fall	erwartet	gemessen
Eigene Änderung vor dem Lauf	durchgehen	Exit 0 ✓
Fremde Sitzung schreibt währenddessen	blocken	Exit 1 ✓
Derselbe Fall mit DEPLOY_ALL=1	durchgehen	Exit 0 ✓
Sauberer Baum	durchgehen	Exit 0 ✓

Priorität 2 — ATS

2.1 Migration — READY_TO_APPLY

lead_inquiries?select=ats_startdatum → **42703, Spalte fehlt**.

20261106000000 ist geschrieben, samt Rollback, im Wächter registriert —

nicht eingespielt. DDL ist aus der Agentensitzung mit service_role nicht möglich (42501); Einspielen geht nur über den SQL-Editor.

Bis dahin ist bewerbung_daten.ats (jsonb) die Wahrheit. Das ist kein Provisorium mit offenem Ende, sondern der dokumentierte Umzugsweg.

2.2 Die 15 Felder nutzbar machen — VERIFIED_LOCAL, Commit 5c0e92ad

Der eigentliche Befund: Die Felder existierten nur als Modul. Ein Grep

über lib app components fand genau **einen** Aufrufer — atsFelderAus zum Lesen. mitAtsFeldern und pruefeAtsFelder wurden von nirgendwo aufgerufen. Kein Schreibweg, keine Maske, kein Feld je gesetzt.

Gebaut:

- setApplicationAtsFelder — Org-Fence, BEWERBUNG_FILTER, Audit über logAuditEventOrWarn. Im Protokoll stehen **nur Feldnamen, keine Werte**:

Freitextnotizen über Bewerberinnen gehören nicht ins Audit-Log.

- pruefeAtsEingabe() neben der Felddefinition statt in der Aktion — damit jeder weitere Schreibweg dieselbe Regel erbt. Sie weist

Formularfelder und unbekannte Schlüssel **ab**, statt sie fallen zu lassen. pruefeAtsFelder allein gäbe hier klaglos {} zurück, und die Maske meldete „gespeichert“, obwohl nichts gespeichert wurde.

- **Maske** in /admin/applications: ein Feld, ein Speichervorgang. Ein Teilformular darf die Angaben eines anderen nicht überschreiben. Die vier Formularangaben sind Anzeige, nicht Eingabe.

- **Sortierung** nach Verwaltungspriorität und nach längster Funkstille. Nicht bewertet heißt dabei **nicht** nachrangig — sonst rutscht genau der unbearbeitete Fall ans Listenende.

- **Warnung an der Maske**, wo „Führungszeugnis liegt vor“ ausgewählt wird: eine Notiz ist kein Nachweis. darfAlsVerifiziertGelten() bleibt false.

42 Tests zu ats-felder. Die Maske selbst ist VERIFIED_LOCAL, nicht

VERIFIED_LIVE: /admin verlangt Anmeldung, und Browser-Verifikation mit Login ist ausgeschlossen.

2.3 Bewerberdaten — VERIFIED_LIVE

Kennzahl	Wert
lead_inquiries gesamt	50
davon Bewerbungen (art oder source)	36
Kundenanfragen	14
mit .ats-Zweig	0
mit .pipeline-Zweig	0
PRIO gesetzt	0
Status	48 new, 2 contacted

Claudia Adjovi: ist in der DB. id=8a0326b0..., status=new, source=engel-bewerbung, eingegangen **02.09.2026** — seit elf Tagen unbearbeitet auf „neu“. Nicht kontaktiert, wie angewiesen.

Mohamed Semmami: nicht in der DB. Null Treffer über Name und E-Mail. Kein künstlicher Datensatz angelegt.

Priorität 3 — Lead Priority Engine

3.1 Produktivdaten — VERIFIED_LIVE

50 offene Vorgänge, ältester **60 Tage**. Kontakalter: 11 × 0–7 Tage, 7 × 8–14, 11 × 15–30, **21 × über 30 Tage**. Die 21 sind unter der neuen Leiter kritisch und füllen den Korb „Lange kein Kontakt“ — die Schwelle

bei 30 statt 7 Tagen war richtig gewählt, bei 7 lägen 39 von 50 darin.

3.2 Deduplizierung — VERIFIED_LIVE, Modul in 45b134ce

2 Telefon-, 2 Namensdubletten, keine E-Mail-Dublette.

Neu lib/leads/dubletten.ts: Gruppen je Merkmal, jeweils mit ihrer Verlässlichkeit. **Führt nicht zusammen** — zwei Zeilen mit derselben Nummer können Mutter und Tochter an einem Haushaltsanschluss sein, und Zusammenlegen wäre unumkehrbar. Leere Merkmale gruppieren nicht, sonst wären 40 Zeilen ohne Telefon eine Dublette. Nummern werden auf Ziffern normiert (+49 / 0049 / Trennzeichen), Fragmente unter acht Ziffern gar nicht erst verglichen. 14 Tests.

3.3 Kunden/Bewerber-Trennung — VERIFIED_LIVE

Der Verdacht lag nahe: 34 Zeilen tragen source='engel-bewerbung', aber art='anfrage' — nur 2 tragen art='bewerbung'. Ein Filter auf art allein zeigte 2 von 36.

Der Code macht das bereits richtig. BEWERBUNG_FILTER in lib/admin/ops.ts prüft beide Bedingungen. Live gegengerechnet:

,

Bewerbungen 36 | Kundenanfragen 14 | offen gesamt 50

Überschneidung 0 | Lücke 0

,

Saubere Partition, kein Handlungsbedarf.

3.4 Follow-up-Historie — VERIFIED_LIVE

Es gibt keine. 0 von 50 Zeilen mit follow_up_date, 0 Zeilen mit pipeline.verlauf, 0 Audit-Einträge zu Leads oder Bewerbungen, lead_activities und lead_notes existieren nicht (404).

Der gesamte Bearbeitungsapparat — Stufen, Wiedervorlagen, Eskalation — hat noch nie an echten Daten gearbeitet. Die Eskalationsleiter aus Phase 5 kann auf diesem Bestand nicht auslösen, weil keine einzige Wiedervorlage gesetzt ist. Das ist ein Betriebs-, kein Codebefund.

3.5 Aging/SLA-Randfälle — ein echter Fehler gefunden, Commit 45b134ce

Ein versehentlich in die **Zukunft** gesetzter letzterKontakt ergab negative Tage → Stufe normal. Ein seit 74 Tagen stiller Vorgang sah damit frisch aus und verschwand aus jeder Arbeitsliste — genau das Verschwinden, gegen das das Modul gebaut ist. Gemessen, nicht vermutet:

,

```
{ "tageSeitKontakt": -5, "quelle": "letzter_kontakt", "effektiv": "normal" }
```

,

Behoben: ein Kontakt in der Zukunft fällt wie ein unlesbarer Wert auf den Eingang zurück. Grenze liegt bei null — „heute“ bleibt gültig.

Weiter abgedeckt: fehlende Zeitstempel, unlesbare Werte, abgeschlossene Vorgänge (altern nicht), Kalendertag-Grenze Berlin/UTC, manuelles Herunterstufen (macht einen alten Vorgang nicht unsichtbar).

Priorität 4 — SEO/Marketing

Zuerst eine Korrektur in eigener Sache: die erste Messung lief gegen www.alltagsengel.org und meldete lauter 404. Die kanonische Domain ist alltagsengel.care. Die 404 waren echt — nur auf der falschen Domain.

4.1 Stadtseiten — VERIFIED_LIVE

Alle 26 Stadtseiten aus der Sitemap: HTTP 200. Sitemap führt 182 URLs.

4.2 Structured Data — VERIFIED_LIVE

Je Stadtseite **2** JSON-LD-Blöcke. Typen: LocalBusiness, FAQPage, BreadcrumbList, City, AdministrativeArea, GeoCoordinates, ContactPoint, ImageObject, Question/Answer, ListItem.

4.3 Canonical — VERIFIED_LIVE

26 von 26 korrekt, jede Seite zeigt auf sich selbst. Keine Abweichung.

4.4 CTA/Conversion — VERIFIED_LIVE

Je Seite mindestens ein Conversion-Pfad (Warteliste/Kontakt/Termin).
robots.txt gibt die öffentlichen Bereiche frei, sperrt /admin, /mis, /api, /engel, /kunde, /fahrer, /auth, /investor, /notfall und nennt die Sitemap.

4.5 Compliance auf der Live-Seite — VERIFIED_LIVE

Stichprobe /alltagsbegleitung/hanau:

Prüfung	Ergebnis
„131“ (Entlastungsbetrag)	38 × vorhanden
„125 €“	0 ×
„nach §45a anerkannt“ o. ä.	0 ×
„Anerkennungsverfahren“	12 ×

4.6 Indexierung — UNKNOWN

Ohne Search-Console-Zugang nicht feststellbar. Dass eine Seite 200 liefert und in der Sitemap steht, sagt nichts darüber, ob Google sie indexiert hat. Wer das wissen will, braucht GSC — raten wäre hier wertlos.

4.7 www.alltagsengel.org — VERIFIED_LIVE, Eigentümer UNKNOWN

Liefert 200 von **GitHub Pages**, Titel „AlltagsEngel e.V.“, ohne Canonical, ohne jeden Verweis auf alltagsengel.care, mit eigener Sitemap aus sechs <http://-html-URLs>.

Das alltagsengel-Repo dieses Kontos hat **kein** Pages aktiviert — die Seite liegt woanders. Ob sie der UG gehört (dann: Weiterleitung auf [.care](http://alltagsengel.care) und Abschaltung der Alt-Sitemap) oder einem fremden e. V. mit ähnlichem Namen, ist von hier aus nicht entscheidbar und sollte nicht geraten werden.

Prüfstand

Lauf	Ergebnis
npx vitest run	10 570 grün , 38 übersprungen
npm run test:unit	2 770 grün , 0 rot
npm run typecheck	sauber
npm run lint	Exit 0
verify-push	synchron (45b134ce)

Offen — und bei wem

Punkt	Bei wem
Repo auf privat oder BFG nach Backup	Inhaber — Kontoeinstellung bzw. freigabepflichtiger History-Rewrite
GitHub-Token rotieren, Credential-Helper einrichten	Inhaber
Google-API-Key in der GCP-Konsole einschränken	Inhaber
Migration 20261106000000 im SQL-Editor einspielen	Inhaber — DDL ist Agenten mit 42501 verwehrt
.org-Domain klären	Inhaber
50 unbearbeitete Leads, ältester 60 Tage	Betrieb
Search-Console-Zugang für die Indexierungsfrage	Inhaber

Alltagsengel UG — interner Bericht, vertraulich.